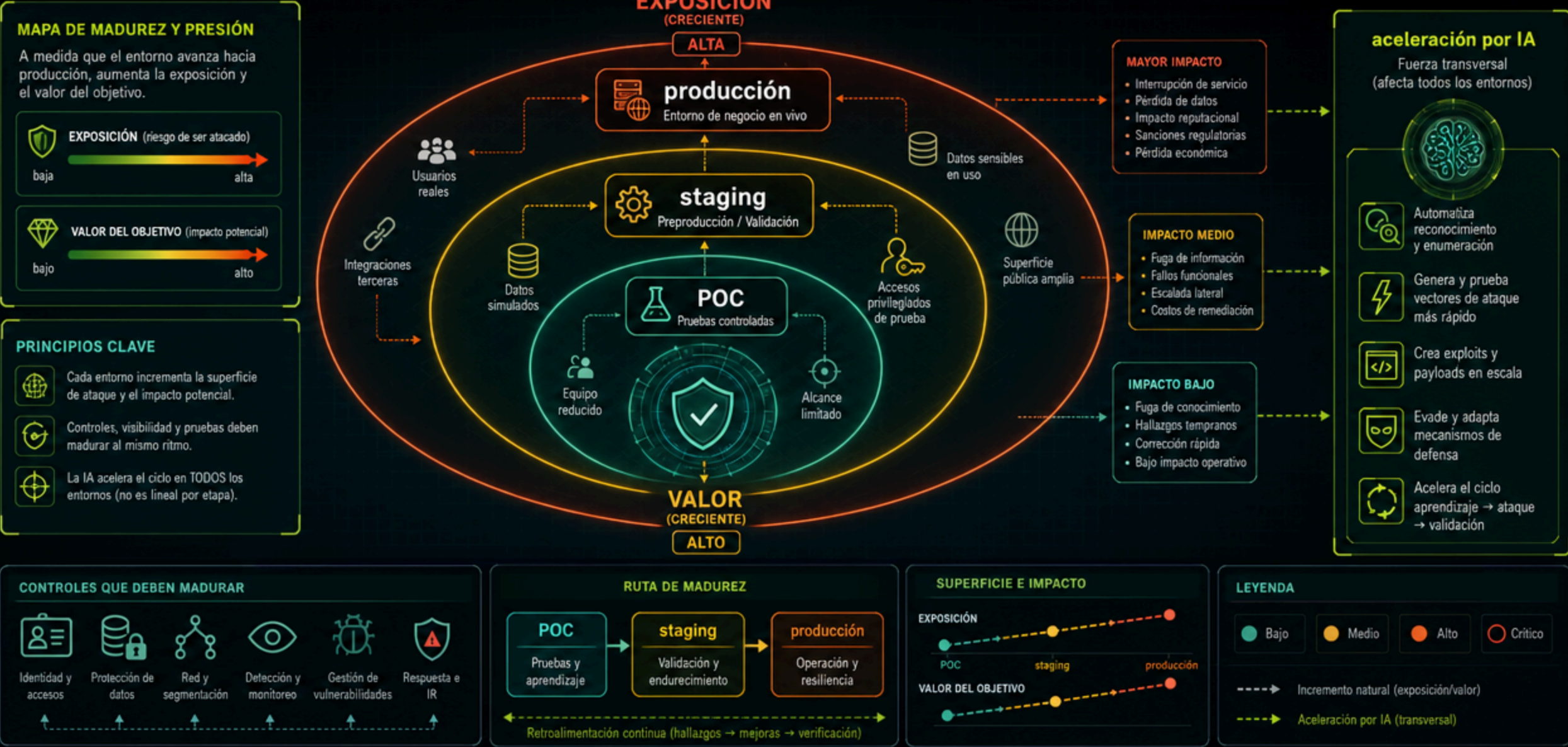


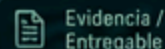
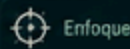
Producción sube exposición y valor del objetivo; IA acelera el ritmo de cambio.



Hoy aterrizamos seguridad en una demo ejecutable

Un recorrido de 4 actos: del riesgo real a la evidencia verificable.

LEYENDA DEL MAPA



CONTEXTO: PRODUCCIÓN CAMBIA LA PRESIÓN

Usuarios reales
Expectativas y SLAs

Datos reales
Valor y sensibilidad

Exposición real
Internet, partners, APIs

Cambio constante
Deploys, features, urgencia

Impacto real
Dinero, reputación, legal

MÁS PRESIÓN

- ✓ Menos tolerancia al error
- ✓ Ventanas de mantenimiento reducidas
- ✓ Decisiones rápidas con alto impacto

RUTA OPERATIVA: 4 ACTOS HACIA UNA DEMO SEGURA

01



1 Riesgo:
por qué producción cambia la presión

ENFOQUE

Entender el contexto para priorizar lo que importa.

CLAVES

- Activos y procesos críticos
- Amenazas y probabilidades
- Impacto, likelihood y apetito
- Priorización de escenarios

ENTREGABLE

Mapa de riesgo priorizado

02



2 Superficies:
checklist, backlog y reporte

ENFOQUE

Descubrir superficies expuestas y convertirlas en trabajo útil.

CLAVES

- Descubrimiento de activos
- Checklist técnico por capa
- Backlog priorizado
- Reporte claro y accionable

ENTREGABLE

Backlog + Reporte técnico

03



3 OWASP:
lenguaje común para decidir qué mirar

ENFOQUE

Usar un marco común para hablar el mismo idioma.

CLAVES

- OWASP Top 10 (2025)
- Mapeo a superficies
- Priorización por riesgo
- Criterios de aceptación

ENTREGABLE

Matriz OWASP + prioridades

04



4 Shannon:
local o staging aislado

ENFOQUE

Ejecutar pruebas en entornos controlados y seguros.

CLAVES

- Entorno local aislado
- Staging con datos sintéticos
- Reglas de seguridad activas
- Trazabilidad de pruebas

ENTREGABLE

Demo ejecutable + Evidencia

DEMO EJECUTABLE Y SEGURA



Valor real,
con control y evidencia.

EVIDENCIA QUE IMPORTA

Hallazgos

PoCs

Fixes

Tareas verificables

PRÁCTICAS TRANSVERSALES (A LO LARGO DE LOS 4 ACTOS)



Seguridad por diseño desde el inicio



Automatización que multiplica



Documentación mínima que habilita decisiones



Comunicación clara con el equipo

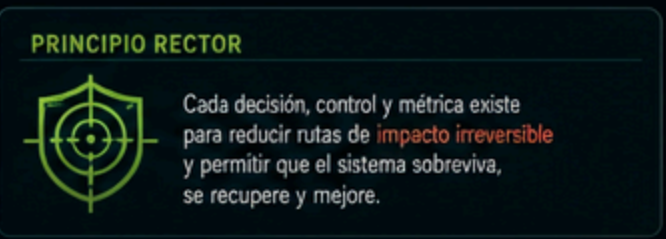
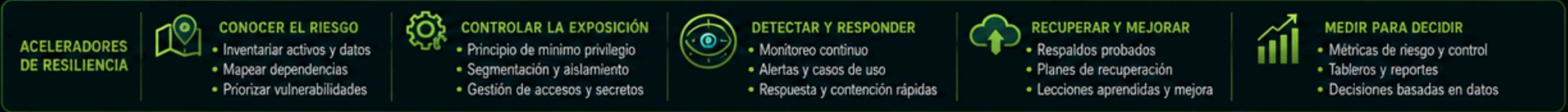


Ética, legalidad y responsabilidad



La clase termina con evidencia: hallazgos, PoCs, fixes o tareas verificables.





ÍNDICE OPERATIVO | Las superficies ordenan la conversación

CÓMO LEER ESTE MAPA

IDENTIFICA
Ubica dónde interactúa tu sistema con el mundo interno y externo.

EVALÚA
Prioriza por impacto y explotabilidad.

ACTÚA
Aplica el flujo operativo de abajo para cerrar el ciclo.

LEYENDA

Interno

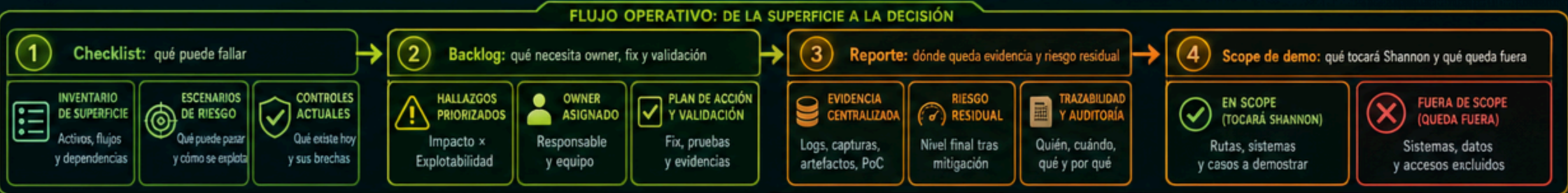
Externo

Compartido

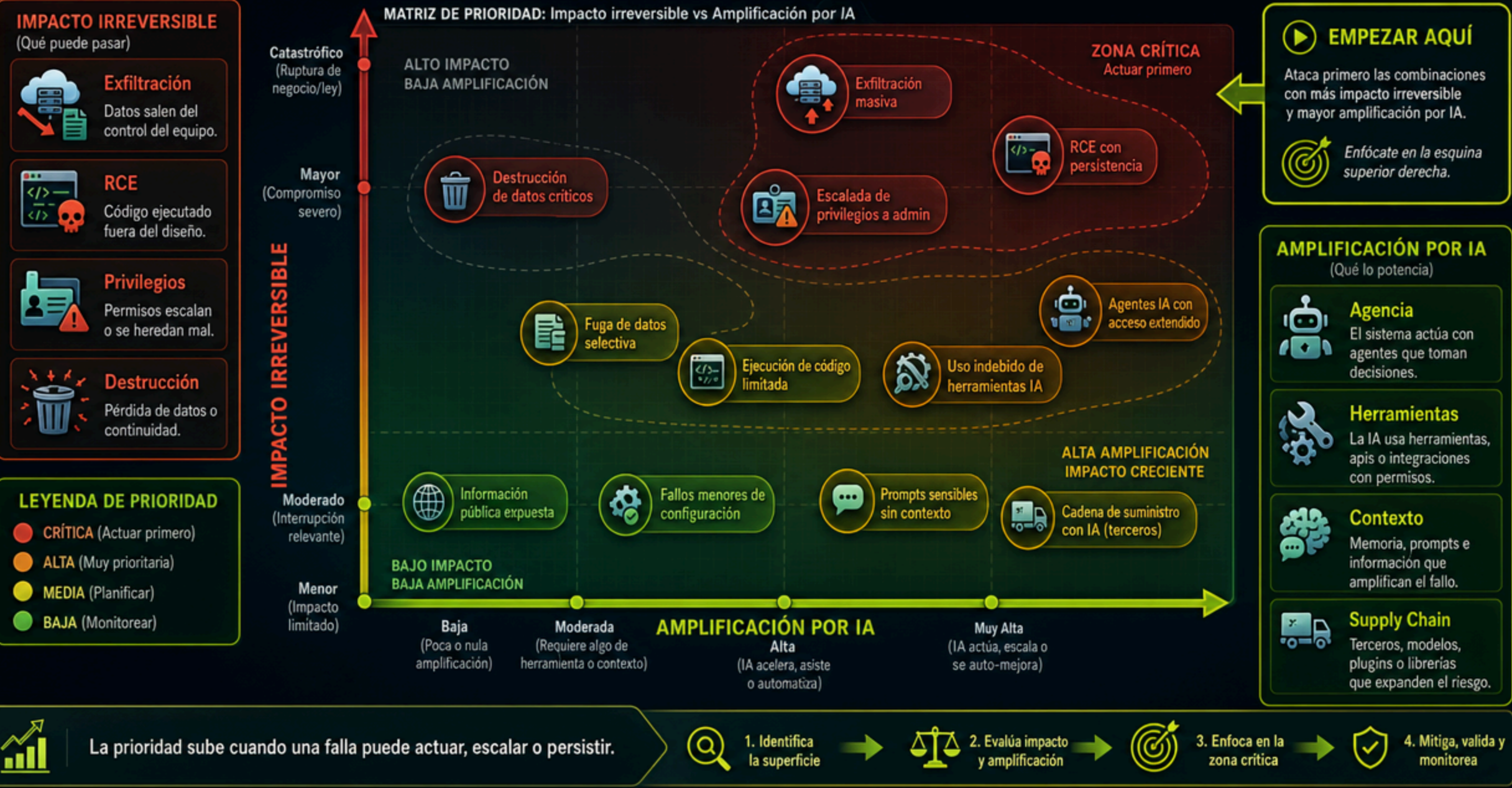
Terceros

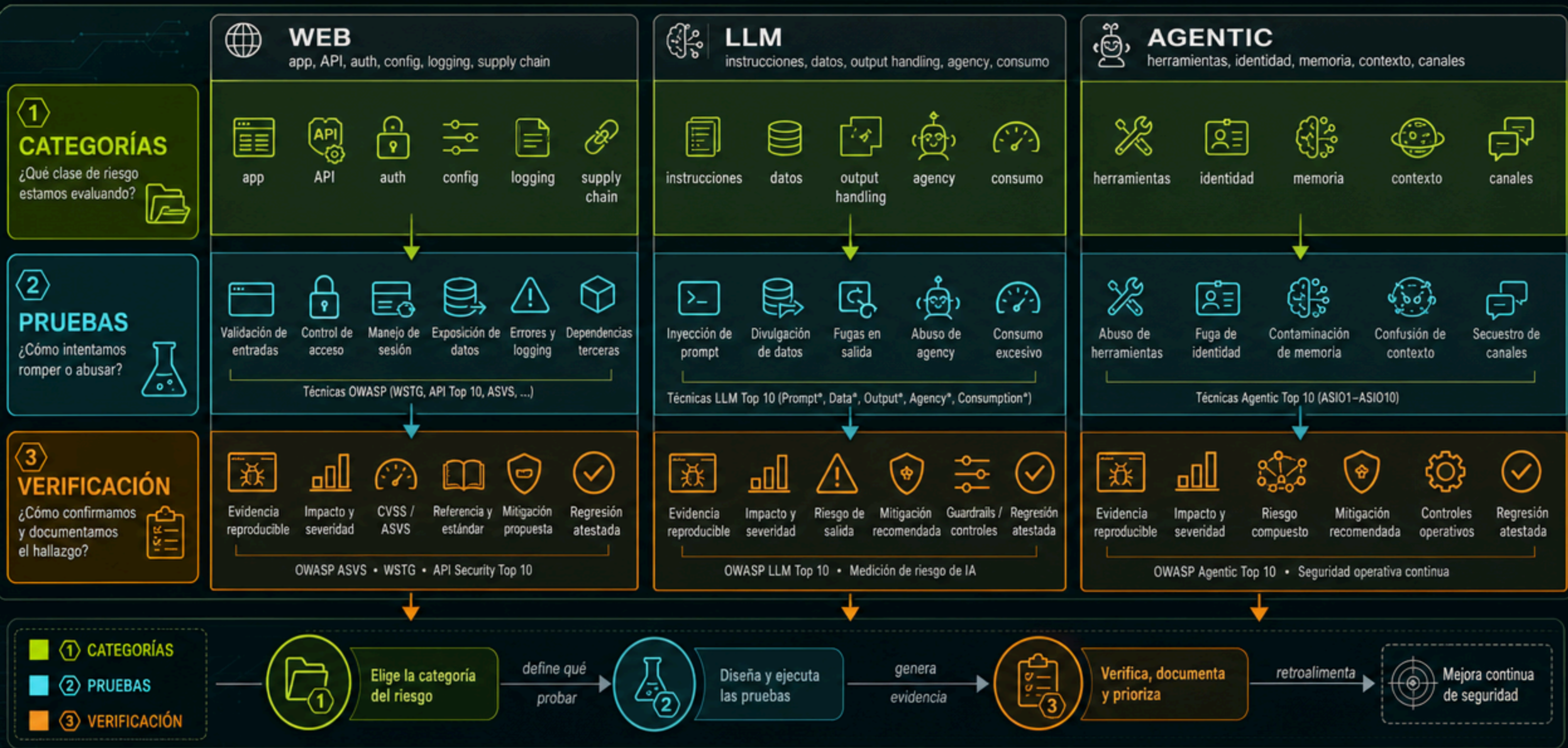
Flujo de interacción

Flujo de riesgo

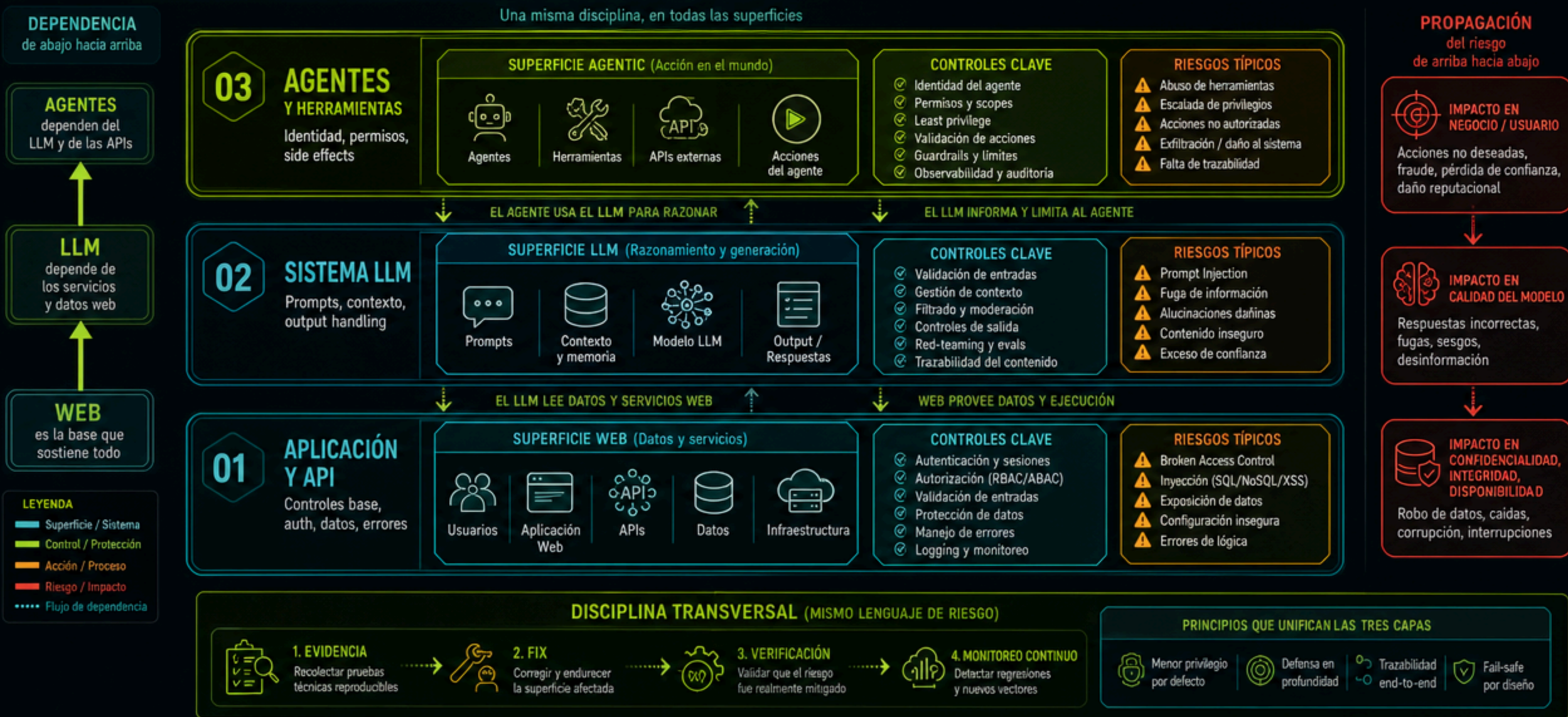


PRIORIZACIÓN | Empieza por impacto irreversible y amplificación por IA



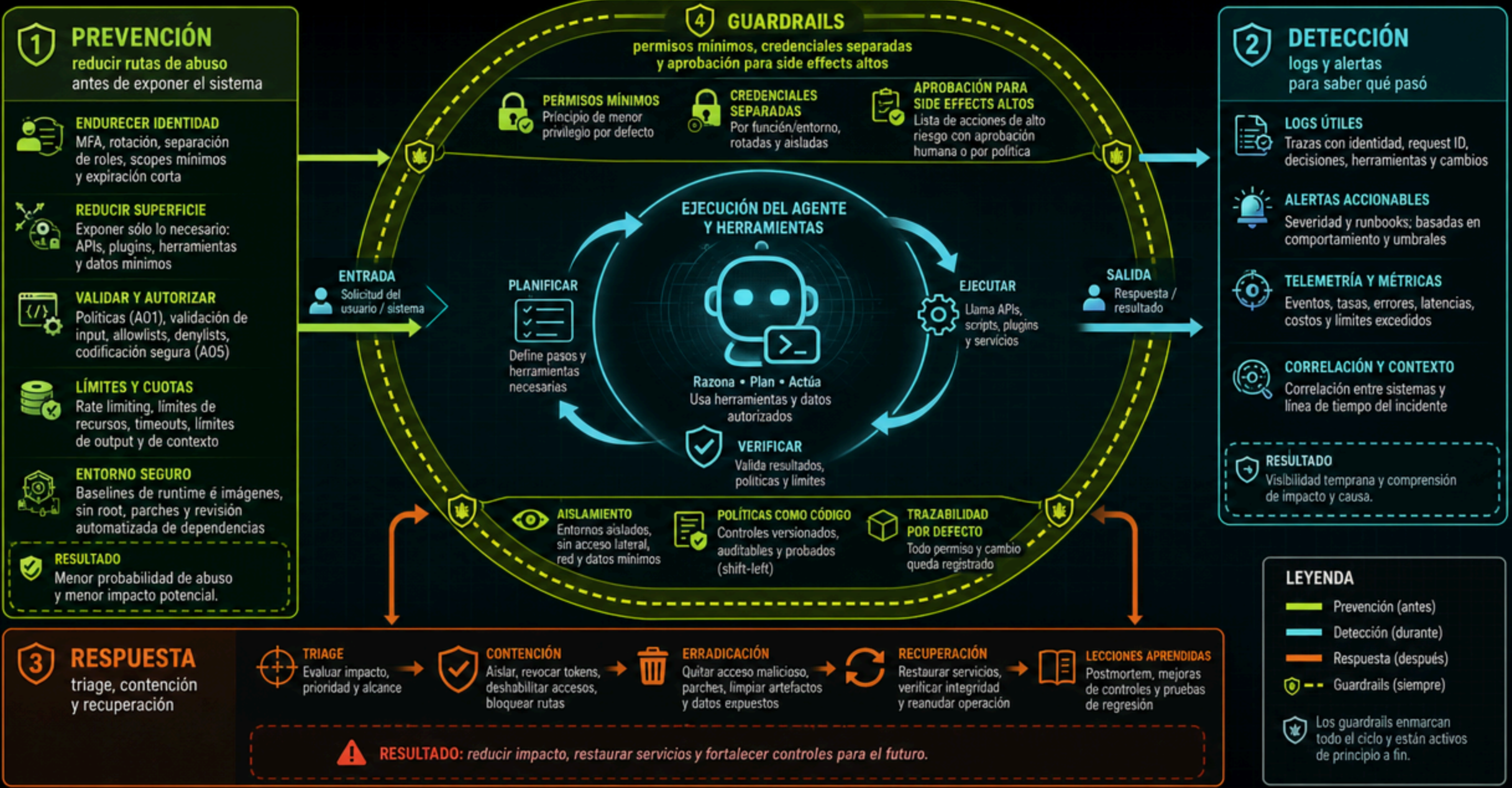


Tres capas, un mismo lenguaje de riesgo



Las categorías cambian; la disciplina es la misma: **evidencia**, **fix**, **verificación**.

HARDENING | Los controles definen qué puede hacer el agente



CONTROLES | De POC a producción: prevenir, detectar, recuperar, limitar



Prevenir:

auth como política, input validation, hardening runtime, supply chain



Detectar:

logs útiles, trazabilidad, alertas accionables



Recuperar:

IR básico, continuidad, evidencias y ejercicios



Limitar agencia:

tool allowlists, scopes mínimos, sandbox y aprobación humana

1. PREVENIR (Diseñar seguro)

2. DETECTAR (Observar y alertar)

3. DETECTAR (Observar y alertar)

3. RECUPERAR (Responder y restaurar)

4. LIMITAR AGENCIA (Contener y gobernar)



IDENTIDAD Y ACCESO

- MFA, SSO, RBAC, mínimo privilegio
- Separación de roles
- Gestión de secretos



APLICACIÓN Y RUNTIME

- Validación de input (AOT)
- Output encoding
- Hardening, parches, distroless
- Deshabilitar funciones innecesarias



SUPPLY CHAIN

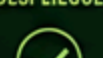
- SCA, SBOM, firma y verificación
- Dependencias mínimas
- Repositorios y artefactos confiables



CONFIGURACIÓN E INFRA

- Baselines, IaC con defaults seguros
- Segmentación y least privilege
- WAF, rate limiting, TLS bien configurado

GATE DE DESPLIEGUE



- Escaneos
- Pruebas
- Aprobaciones



CI/CD Seguro

PRODUCCIÓN (Entorno en vivo)



CONTROLES TRANSVERSALES



LOGS ÚTILES

- Identidad, requests, decisiones, cambios
- Tráns y errores
- Métricas clave



TRAZABILIDAD

- Correlación de eventos
- Request ID / Trace ID
- Auditoría de cambios



ALERTAS ACCIONABLES

- Con severidad
- Runbooks vinculados
- Sin ruido (SLO de alertas)



DETECCIONES

- Anomalías y reglas
- Amenazas y abuso
- Salud del sistema



IR BÁSICO

- Triage, contención
- Erradicación
- Recuperación
- Postmortem



CONTINUIDAD

- Backups probados
- RPO / RTO / MTD
- Planes y responsables
- Conmutación por falla



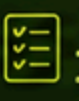
EVIDENCIAS

- Preservación de logs
- Inmutabilidad
- Cadena de custodia
- Retención definida



EJERCICIOS

- Tabletop y técnicas
- Lecciones aprendidas
- Mejora continua



ALLOWLISTS DE TOOLS

- Herramientas permitidas
- Versiones y checksums
- Bloqueo por defecto



SCOPES MÍNIMOS

- Permisos granulares
- Time-bound
- Just-in-time access



SANDBOX / AISLAMIENTO

- Entornos aislados
- Sin salida por defecto
- Recursos limitados



APROBACIÓN HUMANA

- Revisión y aprobaciones
- Políticas y umbrales
- Auditoría de decisiones

IMPACTO SI FALLA



- Incidente
- Fuga de datos
- Indisponibilidad
- Daño reputacional
- Sanciones

GOBERNANZA Y MEJORA CONTINUA



Políticas y estándares



Riesgos y apetito



KPIs y métricas



Revisión de accesos



Gestión de cambios



Lecciones aprendidas

LEYENDA

Prevenición (antes del despliegue)

Detección (durante la operación)

Recuperación (cuando ocurre)

Limitación (seguridad por diseño y control)

Riesgo / Impacto

Principio guía: Defensa en profundidad + mínimo privilegio + observabilidad + respuesta rápida

MÉTRICAS CLAVE



MTTR ↓ (Detección)



MTTR ↓ (Respuesta)

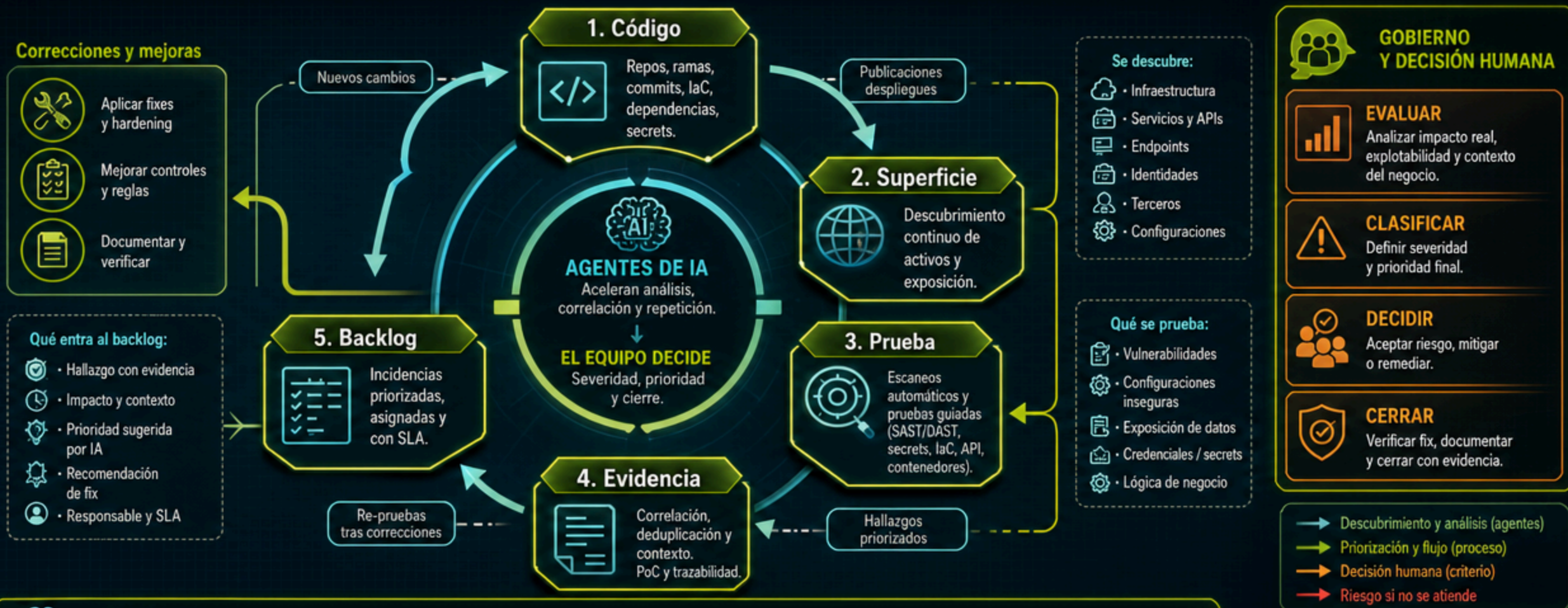


% Cobertura de logs ↑



% Controles efectivos ↑





Los agentes aceleran análisis y repetición; el equipo decide severidad y cierre.

MÉTRICAS QUE MEJORAN



↓ Tiempo de detección (MTTD)



↓ Tiempo de respuesta (MTTR)



↑ Cobertura de superficie



↓ Falsos positivos



↑ Calidad de correcciones



↑ Trazabilidad y cumplimiento

RIESGO SI NO SE ATIENDE



- Exposición continua
- Movimientos laterales
- Pérdida de datos
- Incumplimiento y multas
- Daño reputacional



CÓMO TRABAJA SHANNON

Entiende
el códigoEncuentra
superficiesPrueba y
explotaGenera PoC y
hallazgo

ALCANCE



Código + lógica



Autenticación



APIs y flujos



Datos y negocio

LEYENDA



Entrada / Flujo de información



Procesamiento / Pruebas activas



Salida / Valor generado



Límite de seguridad (no producción)

SHANNON HARDENING SPRINT | Del repo a un hallazgo accionable

LEYENDA

- Flujo principal
- - -> Retroalimentación
- ⇒ Artefactos / Evidencia
- ⇒ Riesgo / Impacto



```
npx @keygraph/shannon setup
npx @keygraph/shannon start -u http://localhost:3000 -r /path/to/repo
```

INICIO
Repositorio y entorno bajo prueba



CIERRE
Hallazgo accionable y riesgo reducido

Retroalimentación continua: ajustar scope, profundizar pruebas, validar fix

CHECKPOINTS DE SEGURIDAD

- No afectar disponibilidad ni datos en producción
- Respetar reglas de engagement y legalidad
- Usar cuentas / datos de prueba
- Minimizar ruido y evitar falsos positivos
- Documentar cada acción y conservar evidencia

PRIORIDAD DE RIESGO
H → M → L
Alto, Medio, Bajo

SALIDAS DE EVIDENCIA

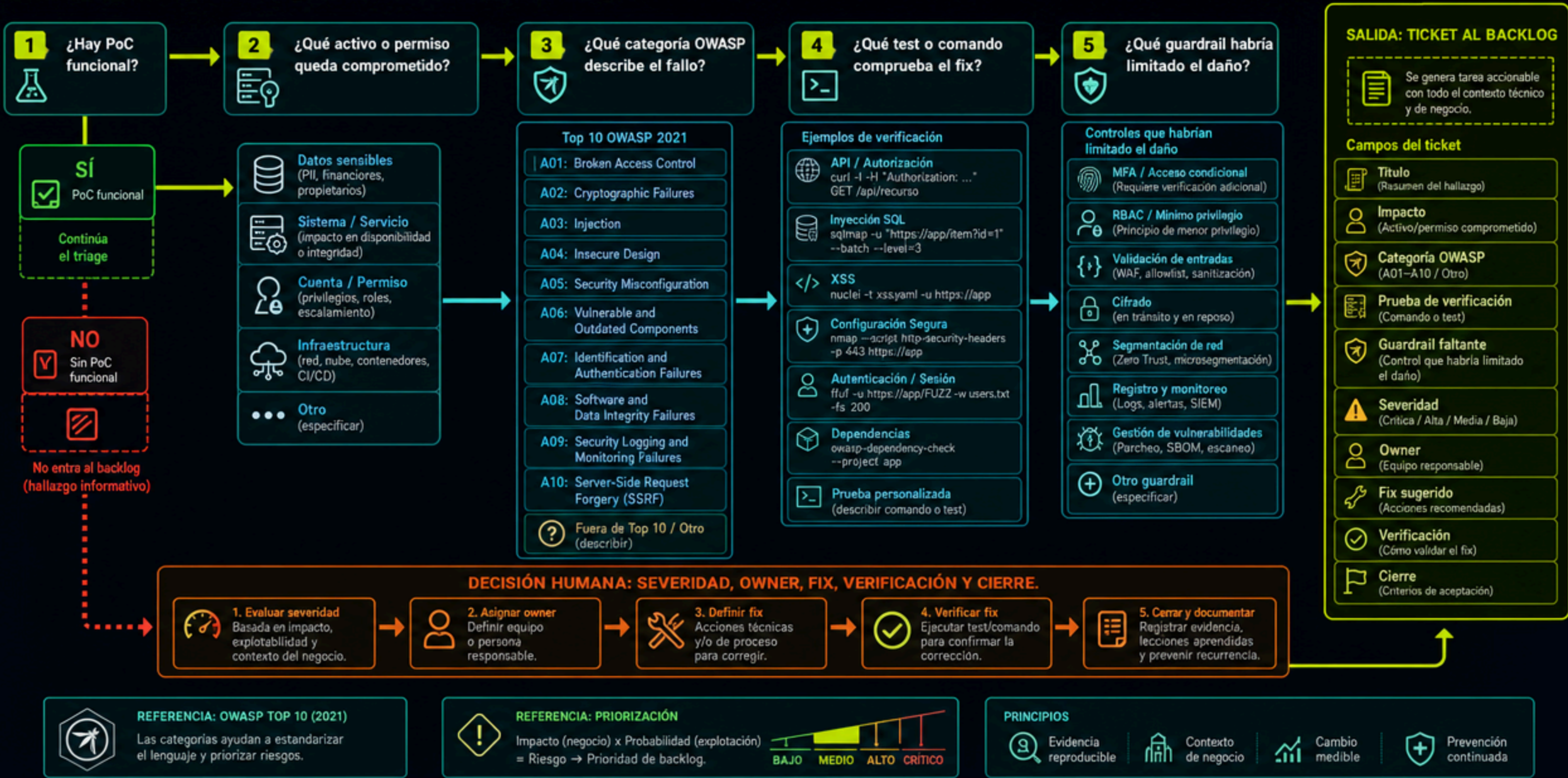
Inventario y diagrama de contexto + Scope y reglas de engagement + Hallazgos y PoC reproducibles + Impacto técnico y de negocio + Recomendaciones y remediación + Evidencia de fix y re-test =

HALLAZGO ACCIONABLE
Riesgo entendido, mitigado y verificado

PRÁCTICAS CLAVE

- No hacer daño
- Trazabilidad total
- Comunicación constante
- Automatizar lo repetible
- Aprender y mejorar

DECISIÓN TÉCNICA | Un hallazgo sirve cuando cambia el backlog



TAREA | Reporte de seguridad del producto

1 Top 5 riesgos: impacto, evidencia y prioridad

#	Riesgo	Impacto (negocio)	Prioridad (IA)	Evidencia clave
1	Control de acceso débil / abuso de privilegios	Alto	CRÍTICA	PoC: escalamiento de privilegios a admin
2	Exposición de datos sensibles	Alto	ALTA	S3 configurado público con PII
3	Inyección en APIs	Alto	ALTA	PoC: SQLi en /api/users sin validación
4	Dependencias con vulnerabilidades	Medio	MEDIA	CVE críticas en librerías (8 hallazgos)
5	Fallas de configuración	Medio	MEDIA	Headers inseguros, CORS abierto

alimentan evidencia

2 Mapa de superficies: qué se revisó y qué queda fuera

SUPERFICIES REVISADAS

Ciudades (Web/Mobile)

API Gateway

Aplicaciones (Front/Back)

Servicios Internos

Bases de Datos

Almacenamiento (Blob/S3)

Infraestructura (IaC/Cloud)

Identidad y Accesos

Terceros y Proveedores

CI/CD y Artefactos

Red y Exposición

FUERA DE ALCANCE

Aplicaciones legadas no soportadas

Entornos de desarrollo personales

Dispositivos de usuario final

Cajas negras de terceros

Legenda

✓ Revisado

○ Fuera de alcance

→ Límite de sistema

→ Flujo de datos

Cobertura

82%

de superficies relevantes cubiertas

3 Hallazgos: severidad, PoC, fix y verificación

Hallazgo	Severidad	PoC / Evidencia	Fix recomendado	Verificación
Escalamiento de privilegios (IDOR)	CRÍTICA	PoC: acceso a /admin/ con ID de otro usuario	Validaciones de autorización por objeto + ABAC	Pruebas automatizadas + revisión manual
Bucket S3 público	ALTA	Bucket accesible sin autenticación	Bloquear acceso público, políticas y cifrado	Public Access = OFF + escaneo
SQL Injection en /api/users	ALTA	Payload: ' OR 1=1 -- retorna datos	Validación de entrada + consultas parametrizadas	WAF + tests DAST
Dependencias vulnerables	MEDIA	8 CVEs críticas en paquetes de terceros	Actualizar + SCA en pipeline	SCA sin críticas pendientes
Headers inseguros / CORS abierto	MEDIA	CORS: * permitido sin restricciones	Política de CORS restringida + CSP	Escaneo de headers conforme

evidencia verificada

4 Controles: prevención, detección, respuesta y guardrails agenciales

Prevención (shift-left)	Detección (continuo)	Respuesta (orquestrada)	Guardrails agenciales (IA segura)
Threat Modeling	DAST / Pentesting periódico	Playbooks por severidad	Límites de acción y permisos (least-priv)
Revisión de código segura (SAST)	Monitoreo y logs centralizados	Containment Automático	Validación de entradas y salidas
Dependencias (SCA)	Detección de anomalías (UEBA)	Notificación y comunicación	Observabilidad de agentes (trazas)
Políticas de IaC y configuración	Alertas basadas en riesgo	Postmortem y lecciones aprendidas	Políticas de uso y filtros de contenido

5 Roadmap: quick wins, mediano plazo y cambios estructurales

QUICK WINS (0-30 días)

Cerrar accesos públicos (S3, CORS, headers)

Parcheo de dependencias críticas

Reglas WAF y bloqueos de ataques comunes

Fortalecer MFA y políticas de contraseñas

MEDIANO PLAZO (30-90 días)

Refactorizar autorizaciones (ABAC)

Pipeline seguro (SAST/DAST/SCA en CI/CD)

Segmentación de red y micro-segmentación

Cifrado en tránsito y en reposo end-to-end

CAMBIOS ESTRUCTURALES (90+ días)

Zero Trust por diseño

Plataforma de identidad unificada y PAM

Automatización SOAR y respuesta

Gobernanza y métricas de riesgo continuas

Impacto esperado:

● Reduce riesgo crítico

● Reduce riesgo alto

● Mejora madurez / eficiencia

SEGURIDAD VERIFICABLE

Riesgo tratado → Evidencia verificada → Trabajo implementado → Valor de negocio protegido.

Seguridad madura cuando el riesgo termina en evidencia y trabajo verificable.